

Assessing Governance, Risk, and Compliance (GRC) for an Organization

Name: Festus Ochieng' Obong'o

Date: 30/01/2026

Role: Junior Cybersecurity Analyst

Section 1: Define GRC Objectives and Scope

1.1 Objectives

The primary goal of this assessment is to modernize DataTrust Solutions' GRC framework to support its rapid growth. Key objectives include:

- **Ensuring Regulatory Compliance:** Aligning internal processes with **SOC 2** and **GDPR** standards to avoid legal penalties and maintain client trust.
- **Establishing Risk Resiliency:** Moving from reactive incident response to a proactive risk management posture.
- **Enhancing Governance:** Creating a centralized oversight structure that aligns security and compliance with long-term business strategy.

1.2 Scope

This assessment covers the following areas of DataTrust Solutions:

- **Departments:** IT, Operations, and Compliance.
 - **Systems:** Cloud-based database (Sensitive Data), ITSM Platform, and the Intrusion Detection System (IDS).
 - **Processes:** Data protection workflows, incident management, and regulatory audit cycles.
-

Section 2: Evaluate Existing Governance Structures

2.1 Governance Strengths

- **Foundational Infrastructure:** Existing use of an ITSM and IDS indicates a technical baseline for governance is already in place.
- **Documented IT Policies:** Core IT operations are currently documented, providing a starting point for expanded policy development.

2.2 Governance Weaknesses

- **Strategic Misalignment:** Governance meetings are irregular and "incident-driven" rather than proactive.

- **Lack of Centralization:** GRC responsibilities are scattered across departments without a central point of accountability (e.g., no Chief Risk Officer or GRC lead).
- **Policy Gaps:** Outdated policies fail to address modern privacy requirements like GDPR.

2.3 Recommendations

- **Establish a GRC Steering Committee:** Form a cross-departmental group to meet monthly and align security efforts with business goals.
 - **Adopt a Standardized Framework:** Implement the **NIST Cybersecurity Framework (CSF)** or **ISO/IEC 27001** to standardize governance.
-

Section 3: Conduct Risk Assessment

3.1 Identified Risks

- **Cybersecurity (High):** Weak encryption on the cloud database and lack of MFA increase the likelihood of a data breach.
- **Operational (Medium):** The ITSM lacks a standardized prioritization matrix, leading to delayed resolution of critical security incidents.
- **Compliance (High):** Inconsistent monitoring of SOC 2 controls poses a high risk of audit failure and loss of certification.

3.2 Recommendations for Risk Mitigation

- **Technical Controls:** Implement **AES-256 encryption** for data at rest and enforce **Multi-Factor Authentication (MFA)** for all administrative access.
 - **Operational Standards:** Define an **Incident Response Plan (IRP)** within the ITSM that categorizes incidents by risk level rather than arrival time.
-

Section 4: Review Compliance Requirements

4.1 Compliance Status

- **SOC 2: Non-Compliant/High Risk.** Evidence collection is manual and inconsistent, which will not satisfy the rigorous requirements of a Type 2 audit.
 - **GDPR: Non-Compliant.** Lack of formal data transfer policies and a two-year gap in security training represent major violations of PII protection standards.
 - **Internal Policies: Gap identified.** Training mandates are not being met, creating a "culture of non-compliance" that increases human-error risks.
-

Section 5: Assess GRC Integration

5.1 Integration Observations

DataTrust currently operates in **silos**. Compliance efforts are viewed as a "check-the-box" activity for the compliance team, while IT views risk management as a technical troubleshooting task. There is no automated data flow between the IDS (threat detection) and the risk register (impact analysis).

5.2 Recommendations for Integration

- **Shared Data Repository:** Use a centralized platform where IT, Risk, and Compliance teams can see the same real-time data.
 - **Cross-Functional Workflows:** Ensure that every high-priority alert in the IDS automatically triggers a review in the risk management workflow.
-

Section 6: Analyze GRC Tools and Technology

6.1 Current Tools and Technology

- **Manual Tracking:** Reliance on spreadsheets for risk and manual logs for compliance is inefficient, prone to human error, and lacks auditability.
- **Limited Automation:** The current IDS is a standalone tool with no integration into a broader security orchestration or reporting system.

6.2 Recommendations for Technology Upgrades

- **Implement a GRC Software Platform:** Deploy tools like ServiceNow GRC, LogicGate, or OneTrust to automate evidence collection and risk tracking.
 - **SIEM Integration:** Integrate the IDS with a **Security Information and Event Management (SIEM)** system to automate compliance reporting and threat correlation.
-

Section 7: Report Findings and Action Plan

7.1 Key Findings

DataTrust is at a critical juncture. Rapid growth has outpaced governance, leaving the company vulnerable to **data breaches** and **regulatory fines**. The primary issues are manual processes, lack of centralized accountability, and outdated employee training.

7.2 Action Plan

Phase	Action Item	Timeline
Phase 1: Immediate	Conduct mandatory GDPR/Security training; Enable DB encryption.	0–30 Days
Phase 2: Governance	Establish GRC Steering Committee; Hire/Appoint GRC Lead.	31–60 Days
Phase 3: Technology	Procure GRC software and begin manual data migration.	61–120 Days
Phase 4: Optimization	Automate SOC 2 monitoring; Conduct mock audit.	120+ Days

Conclusion

DataTrust Solutions must shift from a reactive "firefighting" mode to a structured, integrated GRC model. By centralizing governance, automating risk and compliance tasks, and investing in modern GRC technology, the organization can turn its compliance requirements into a competitive advantage, ensuring long-term stability in the Austin IT services market.